14 — Data breach procedure

Français (version de référence) : ../fr/14-procedure-violation-donnees.md

> **TEMPLATE — INTERNAL DOCUMENT.** To be adapted to the real team; legal deadlines to be confirmed.

Header	
Jurisdiction	DRC — Digital Code, Book III (security, notification)
Assumptions	H-03, H-05 (competent authority), H-15 (72-hour deadline, secondary source)
Sources	S01, S16 — see 00-legal-research.md § 7
Clauses to validate	V-06 (deadline and content of notification)
Version	[NUMBER] of [DATE]

1. Definition

Data breach: any security incident leading, accidentally or unlawfully, to destruction, loss, alteration, disclosure of or unauthorised access to personal data (examples: exposed database, compromised administrator account, lost backup, sending to the wrong recipient, ransomware).

2. Roles

Role	Person	Deputy
Incident lead	[NAME]	[NAME]
Data protection officer	[NAME]	—
Technical (server, database)	[NAME]	[NAME]
Customer communication	[NAME]	[NAME]
Legal counsel	[FIRM]	—

3. Steps and deadlines

Deadline (from detection)	Action
immediately	record the detection time in the incident register; alert the incident lead
< 4 h	contain: cut the compromised access, revoke sessions (per business or globally), change the secrets involved (`NH_SECRET_KEY` only if necessary: see the consequences in the configuration guide), preserve logs (`journalctl -u nhill-server`, audit log)
< 24 h	assess: data and people concerned, businesses affected, risk to individuals; **inform the customer businesses concerned** (we are their processor, template 06)
< 72 h **[TO VALIDATE: V-06]**	**notify the data-protection authority** for processing where Nhill is controller, if the breach presents a risk; businesses notify for their own processing, with our help
without undue delay	inform the people concerned if the risk is high (plain language: what happened, consequences, measures, advice, contact)

Deadline (from detection)	Action
< 30 days	root-cause analysis, fixes, testing, report; update of the security audit

4. Content of the notification to the authority

Nature of the breach; categories and approximate number of people and records; contact of the officer; likely consequences; measures taken or planned. If not everything is known, notify what is known and complete later.

Authority: [NAME, ADDRESS, E-MAIL, FORM — ARPTC on a provisional basis or ARPTIC, to confirm, H-05].

5. Incident register

Every incident, even if not notified, is recorded:

Detection date	Description	Data / people	Risk	Measures	Notified to authority (date)	People informed (date)	Closed

6. Exercise

Simulate an incident [once a year] (for example: leaked backup) and measure the real response times.